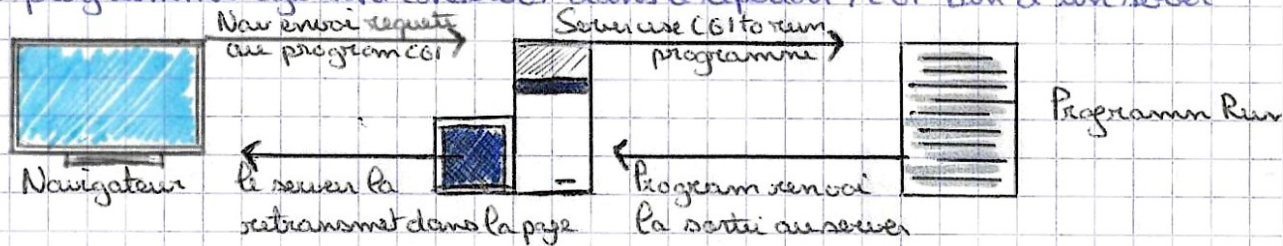
Attaquer les application Common Gateway Interface (CGI) - (Shellshock) :

Comme on l'as vu les CGI permettent de générer des pages web dynamique, ç qui est essentiellement un middleware (intergiciel) entre les serveurs web les scrip ts et programmes cgi sont conservés dans le repertoir /CGI-bin d'un server



- De maniére generale les etapes sont les suivantes

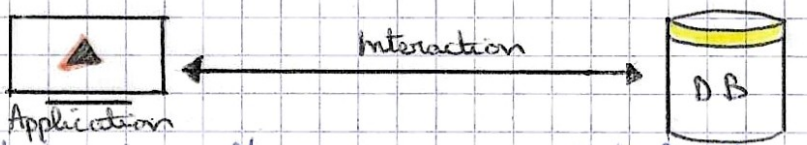
1- Un repertoir contenant les scripts cgi est créé sur le serveur web ce repertoir est généralement nommé CGI-bin/. L'utilisateur de l'application renvoi une ~~URL~~ re quete au server via une URL par exemple https://acme.org/cgi-bin/script.pl, le serveur exécute le script et renvoi la sortie resultante au client.
Ce qui créé un processus par requete http et consomme beaucoup de memoire cette techn logie est désuette et ne fonctionne plus pour des sites web modernes

Shellshock alias CVE-2014-6271
Une touche bash < 4.3 reside dans le fait que bash permet de partager des fonctio avec des processus enfant via des variables d'environnement en utilisant une syntax spécifique. La vulnérabilité reside dans le fait que qui si on fermait la fonction et rajoutait du texte après il serait exécuter comme une commande system, le "pay load" injecté ressemble a ca () { :;}; id . Le rapport avec CGI ? Lorsque un serveu apache recoit une requete HTTP pour un ~~server~~ script CGI il la traduit en variable d'environnement par exemple le contenu du header useragent (ou on peu mettre notre payload) devient une variable d'environnement HTTP_USER_AGENT

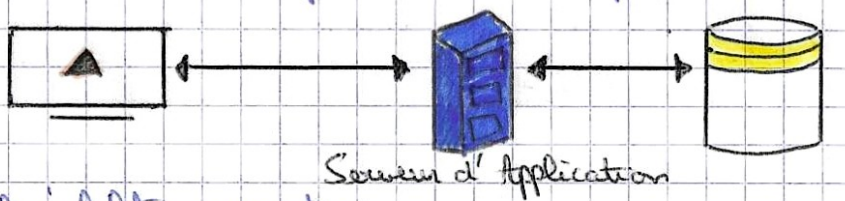
Attacker les applications clients lourds :

Une application client lourde est un logiciel installé directement sur notre ord nateur qui peux fonctionner sans internet (Serveurs Externes)
Elles peuvent avoir des failles de sécurité uniques elles se compose ent deux types d'architectures

1- A deux niveau, l'application se connecte directement à une DB



2- A trois niveaux l'application se connecte à la DB en passant par un serveur inter médiaire (+ Sécurisé, car la DB n'est pas directement exposée)



- Vulnérabilités courantes:

Credentials Hardcoder: les developpeurs laissent parfois des usernames mot de passes e clés API directement dans le code ou les fichiers de conf de l'application
Le stockage de données non sécurisé, Pour exemple on peu lancer l'application et avec un o il d'analyse réseau les fichiers temporaires qu'elle crée et rapidement les capturer, on peu également analyser le code avec des outils de reverses et bien sur le point de vu reseau en capturant les requetes qu'elle emet.
En resumé attaquer une telle infra consiste à enqueter sur l'application sous tous ses angles (fichiers, memoire, trafic reseau, etc)...